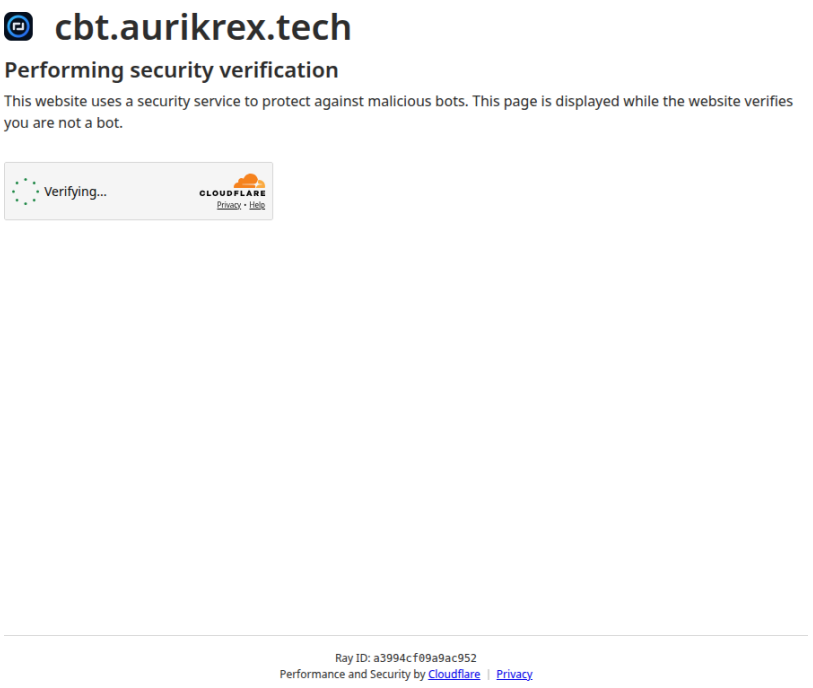
Aurikrex CBT App — Full Repo-Wide Audit Report

Product: JAMB UTME Prep / Aurikrex Exam Arena
Repository: `komfalcon/CBT` (`main`, audited commit `f337b8b`)
Live application: https://cbt.aurikrex.tech/
Audit date: 11 September 2026
Scope: Read-only investigation of the repository, production public routes, production HTTP behavior, build reproducibility, and available unauthenticated flows. No code changes, branch creation, or commits were made.

Visual evidence

The following screenshot was captured from the production landing page at 1440 × 900 using an isolated Chromium profile. The numbered colored rectangles seen in connected-browser inspection captures are tool overlays and are not included here.



Executive verdict

Launch readiness: NO-GO for a paid or exam-critical launch. The public shell is polished and the principal public/support/legal pages are present, but the release still has a material operational verification gap, inconsistent product claims, content-quality defects in the question bank, security/maintenance debt in the dependency graph, and incomplete evidence for authenticated exam, CBT-key, AI, admin, and payment flows. The repository still points `frontend/.env.production` at the retired Render origin `https://cbt-vl4x.onrender.com`; that origin did not respond to direct `/health` or `/api/health` requests during the audit. Per the owner's clarification, PXXL is now the backend provider, but no PXXL endpoint or deployment configuration is present in the audited repository, so PXXL availability and end-to-end behavior were not tested. The launch blocker is therefore the stale configuration plus the missing PXXL verification, not Render availability itself.

The implementation does have positive foundations. A clean install and production build completed for the root, frontend, and backend. The backend enables Helmet, CORS controls, a CSRF check, and a global validation pipe. The public legal pages are substantive and mention Nigerian data protection, Paystack, cloud providers, CBT keys, and FalkeAI. These strengths do not offset the need to prove the authenticated and payment-critical paths against a healthy API and to remediate the content and dependency findings below.

Severity summary

Severity	Count	Meaning
Critical	0	No critical production defect was confirmed in the audited evidence after the backend clarification.
Major	10	A high-impact defect, stale deployment configuration, or release blocker requiring remediation before broad launch.
Minor	8	A lower-impact inconsistency, quality issue, or maintainability problem that should be addressed before polish sign-off.

Priority-ranked findings

P0 — Critical (none confirmed)

ID	Area	Finding and evidence	User impact	Recommendation
OPS-01	Backend configuration / deployment verification	The frontend production configuration still points to the retired Render origin `https://cbt-vl4x.onrender.com` (`frontend/.env.production`). Direct requests to both `/health` and `/api/health` timed out, confirming that the repository's configured origin is stale or unavailable. Per the owner's clarification, PXXL is now the backend provider, but the audited repository contains no PXXL endpoint or deployment configuration, so PXXL availability and core-flow behavior were not verified.	A deployment built from the audited repository can direct the frontend to the wrong backend, blocking sign-in, registration, CBT-key login, session creation, answer saves, FalkeAI, payment verification, and admin data.	Update the production configuration and deployment secrets to the authoritative PXXL origin, add external uptime monitoring and a deployment smoke test, and verify auth, exam, AI, and Paystack flows through the real PXXL-backed frontend origin before launch.

P1 — Major

ID	Area	Finding and evidence	User impact	Recommendation
CNT-01	Question bank / explanations	The bundled Chemistry data contains explanations that openly re-check their own calculations, admit that options do not match, suggest changing the question, or select the “closest” option. Examples include `backend/data/chemistry_questions.json:6852`, `:3492`, and `:3588`. The source text includes phrases such as “Wait, let’s check,” “there might be a typo,” “closest conceptually,” “I will adjust,” and “assume.”	Students can be taught a wrong answer or lose trust in the answer key. This is especially serious for a paid UTME preparation product.	Run a subject-matte review and calculation validator over every question/explanatio pair. Do not publish explanations that hedge, invent assumptions, or contradict the supplied options.
CNT-02	Marketing claims	The landing page presents “100K+ students,” “4.9 average rating,” “0+ practice questions,” and “0+ average score boost” in the live page content. The auth page presents “100K+ students,” “1M+ questions,” and “4.9 rating.” The arena page presents “2,481 learners online,” “68/100,” and a named candidate “David.” These are inconsistent across product surfaces and some values appear to be static demo content.	Misleading or unverifiable claims can create consumer-trust and advertising risk. The zero-value metrics visibly weaken credibility.	Establish one verified source of truth for metrics, remove demo value from production, an label illustrative UI a illustrative when it is not live data.
OPS-02	Authenticated flow verification	The API timeout prevented end-to-end verification of email login, registration/verification, Google sign-in, CBT-key login, password reset, and MFA. The source also contains `const token = '';` in `frontend/src/features/exam/ExamConsole.tsx:178`, while the page calls authenticated exam APIs using that token.	If the token is not injected elsewhere by the API layer, exam session fetch/save/submit requests will fail even when the API is healthy. This path needs runtime proof, not only a successful TypeScript build.	Trace the auth toke source end to end, remove dead or misleading token placeholders, and execute real authenticated smok tests with a disposable test account.
EXAM-01	Exam state / flag tracking	`ExamConsole` stores flagged questions in local React state (`frontend/src/features/exam/ExamConsole.tsx:348-355`) and resets the set after fetching a session (`:195-197`). The answer and time autosave payloads only pass `answers` and `timeRemaining` (`:261`, `:275`); flags are not included in the persistence payload.	A reload, navigation, crash, or device switch can lose the candidate’s flags even though the UI describes exam integrity and automatic saving.	Persist flags in the session model and API, or explicitly document that flags are device-local. Te reload, reconnect, and resume behavior.
EXAM-02	Timer / submission error handling	When the timer reaches zero, `autoSubmitExam` submits and, on any error, logs the error and navigates to `/dashboard` (`frontend/src/features/exam/ExamConsole.tsx:240-250`). The candidate is not shown a submission failure or given a recovery path.	A timeout during autosubmit can silently discard the candidate’s result and make the exam appear to vanish.	Make timeout submission idempotent, retain the session, show a recoverable failure state, and reconcile submission status server-side before redirecting.

ID	Area	Finding and evidence	User impact	Recommendation
PAY-01	Payment verification	The payment service throws a generic configuration error when the Paystack secret is absent (`backend/src/payments/payments.service.ts:24-27`), and the live API could not be reached to verify initialization, callback, webhook, duplicate-reference handling, or subscription activation.	Payment can be charged without entitlement activation, or the UI may be unable to distinguish provider, configuration, timeout, and verification failures.	Add a production payment smoke tes using Paystack test mode, preserve provider error codes in server logs witho exposing secrets, make verification idempotent, and show a clear pending/retry/suppo state to the candidate.
SEC-01	Dependency security	`npm audit --omit=dev` reported 5 vulnerabilities in the frontend (3 moderate, 2 high) and 31 in the backend (1 low, 20 moderate, 10 high). The clean install also reports deprecated Apollo and related packages.	Known vulnerable production dependencies increase attack surface and complicate security review.	Triage the audit tree upgrade or replace vulnerable production packages, and add an audit threshold t CI.
SEC-02	Content injection / SVG data	The question bank contains raw `diagram_svg` strings, including external `<image href="https://example.com/..."> ` references in `backend/data/history_questions.json:22954` and `:22986`.	External diagram loads can break, leak requests, or create an unsafe rendering boundary if SVG is injected without sanitization.	Sanitize SVG with a allowlist, disallow external references and test the rendering path with hostile SVG payloads.
OPS-03	Reproducibility / runtime mismatch	The root package declares Node `20.x`, while the audit environment used Node `22.13.0`, producing an `EBADENGINE` warning. The build still passed, but the repository does not prove the declared production runtime matches the deployed runtime.	Future dependency or runtime differences can make a green local build diverge from production.	Pin and document the supported Node version, build in CI and deployment wit that version, and fai on unsupported engines if compatibility is not intended.

P2 — Minor

ID	Area	Finding and evidence	User impact	Recommendation
UX-01	Design system / typography	The public landing and arena surfaces use different visual language and navigation labels: the main product uses “Aurikrex Exam Arena,” while `/arena` uses “EXAM ARENA,” a different header, a named sample candidate, and a different cyan/blue accent system. Auth and support pages also use separate layouts.	The app feels like multiple products and weakens brand continuity.	Consolidate typography, naming, header behavior, accent tokens, logo lockup, and spacing rules into one system.
UX-02	Light/dark mode	Public pages expose a theme toggle, but the live audit was performed in dark mode and source inspection shows many page-specific dark color literals alongside tokenized theme classes. A full light-mode pass was not possible through the unauthenticated live API state.	Light-mode contrast and component parity remain unproven, particularly for admin/exam views.	Add automated visual snapshots for both themes at desktop and mobile breakpoints; verify text, borders, icons, charts, dialogs, and selected states.
UX-03	Responsive navigation	The exam subject strip uses `min-w-[145px]` buttons inside an `overflow-x-auto` container (`ExamConsole.tsx:501-515`). This contains the strip but creates a horizontal scrolling interaction at narrow widths.	Candidates may miss subjects or interpret the scrollable control as a broken layout on phones.	Use a compact subject selector or accessible horizontal tab scroller with visible overflow affordance and keyboard support.
A11Y-01	Accessibility	The live browser inventory shows a Google sign-in element exposed as a `div` with `role="button"` rather than a native button. Several icon-only controls rely on `title` or visual context; a complete keyboard and screen-reader pass could not be completed without authenticated routes.	Keyboard activation, focus behavior, and accessible naming may be inconsistent.	Prefer native buttons, verify `Enter`/`Space`, add explicit accessible names, and run axe plus keyboard-only tests across all route families.
A11Y-02	Focus states	Some source components include `focus-visible:ring-2`, but the public support form and several shared controls use `outline-none` without a clearly paired focus style in the same declaration.	Keyboard users may lose the focus position in forms and navigation.	Enforce a shared focus-visible token in the base button/input components and test on dark and light backgrounds.
SEO-01	Metadata	`App.tsx` sets title, description, Open Graph title/description, and canonical per route, but it does not set route-specific `og:url`, `og:image`, or Twitter image metadata. The base HTML also has a generic `twitter:card` of `summary`.	Social previews are incomplete and route sharing may show no branded image.	Add a stable preview image and route-specific `og:url`, `og:image`, `twitter:image`, and structured organization/product metadata.

ID	Area	Finding and evidence	User impact	Recommendation
PWA-01	PWA / icon consistency	The Vite PWA manifest uses `Aurikrex CBT Portal` and short name `CBT Portal`, while the browser title and brand are `Aurikrex Exam Arena`. HTML references `favicon.ico`, `favicon.svg`, and `apple-touch-icon.png`; the manifest references four PWA PNGs.	Installed apps and browser tabs can show different product names and icon treatments.	Use one approved product name/short name and verify every referenced icon exists, has the intended maskable safe area, and renders consistently.
PERF-01	Bundle / assets	The production frontend build is approximately 2.9 MB uncompressed, including a 1.0 MB JavaScript chunk, 164 KB CSS, and roughly 364 KB of images. KaTeX ships many font variants.	Initial load and low-bandwidth Nigerian mobile performance may suffer.	Split heavy routes, load KaTeX and charts on demand, subset fonts, compress images, and measure Core Web Vitals on a mid-range mobile profile.
PERF-02	Frontend quality	`npm run lint` completed with 41 warnings, including unused imports/variables in admin, auth, AI, exam, results, and dashboard files.	Warnings make real regressions harder to detect and indicate unfinished code paths.	Treat lint warnings as CI failures or reduce the warning count to zero before release.
CONTENT-01	Placeholder/test data	The source contains a `dummyPassword` match and generated diagram content with `dummy points`; History diagrams use `example.com` image URLs. These are not acceptable in a production question bank.	Broken images, test-looking content, and possible accidental credentials undermine trust and may surface to students.	Remove test fixtures from production data, validate all URLs, and add a content release gate.
LEGAL-01	Compliance readiness	Privacy and terms pages exist and are not placeholder text. The privacy notice references the Nigeria Data Protection Act 2023 and earlier NDPR, Paystack, Google, SeekAI, Turso, DigitalOcean, and Cloudflare. This is a good baseline, but the audit could not verify that production runtime behavior exactly matches those disclosures because the API was unavailable.	A policy that names providers or retention practices not implemented in production can become inaccurate.	Reconcile the policy with deployed infrastructure, confirm controller/contact details, publish a data-subject request workflow, and obtain Nigerian privacy counsel review before paid scale.
ADMIN-01	Admin route	`/admin/overview` rendered “Checking your admin session…” during the live audit and did not reach a usable admin page before the API timeout. Source routing does wrap admin pages in `AdminRoute`, which is a positive control, but it is not sufficient to verify redirect, role enforcement, or session expiry.	Operators may be unable to manage candidates, keys, billing, or questions, and access-control behavior is unproven.	Test admin login, role separation, session expiration, direct deep links, and API authorization with non-admin and admin fixtures.

Route and feature coverage

Surface	Live observation	Source observation	Audit confidence
Landing `/`	200; public marketing page rendered.	Route metadata and landing components present.	High for public shell; medium for claims and responsive parity.
Auth `/auth`	200; sign-in, sign-up, CBT-key, Google sign-in controls rendered.	Auth API, email verification, password reset, MFA, and Google SDK paths present.	Low for functionality because API timed out.
Exam arena `/arena`	200; separate arena-style public experience rendered with static flight-deck data.	Separate page and copy from main landing.	High for display; low for whether advertised modes are wired to real sessions.
Help `/help`	200; 15 answers and search/category controls rendered.	Substantive content present.	High for existence/content; medium for search behavior.
Contact `/contact`	200; form prepares a mailto message rather than submitting to a support backend.	Source explicitly says the email app should open.	High. This is a deliberate design choice, not a defect by itself.
Privacy `/privacy`	200; substantive policy rendered.	NDPA/NDPR, providers, retention, rights, young users described.	High for presence; medium for runtime alignment.
Terms `/terms`	200; substantive paid-plan, refund, acceptable-use, and AI disclaimer content rendered.	Paystack and monthly-plan language present.	High for presence; medium for runtime alignment.
Dashboard, exam hub, mock setup, question bank, exam console, results	Protected routes not meaningfully exercised because no authenticated session/API.	Routes and components exist.	Low; requires authenticated test fixture.
Admin overview, candidates, keys, billing, questions	Loading state observed; no usable admin data.	Admin route guard and pages exist.	Low.
Payment/subscription	No live checkout or verification test completed.	Paystack service and terms exist.	Low; release blocker until verified.
FalkeAI	Public landing describes it; no authenticated chat run completed.	AI widget/source present.	Low.

Build and reproducibility results

A clean audit copy was created so the repository itself was not changed. Root `npm ci --ignore-scripts`, frontend `npm ci`, frontend lint, frontend build, backend `npm ci`, and backend TypeScript build all completed successfully. The frontend build transformed 1,925 modules and produced a Vite/PWA build of approximately 2.9 MB uncompressed. Lint passed with **0 errors and 41 warnings**. The install emitted an unsupported-engine warning because the repository requests Node 20.x while the audit runtime was Node 22.13.0. Production dependency audit reported **5 frontend vulnerabilities** and **31 backend vulnerabilities**.

This means **clean installation and compilation are reproducible in the audit environment**, but production reproducibility is not fully proven until the declared Node version is pinned in CI/deployment, the stale Render origin is removed, and the PXXL-backed API environment is healthy.

Accessibility, responsive, and visual notes

The public pages use a coherent dark visual direction with rounded cards, blue/purple accents, Sora/Inter typography, and repeated “BY AURIKREX” lockups. The main design issue is not a single isolated spacing defect; it is **system fragmentation** between the main landing, `/arena`, auth, support/legal shells, and protected exam/admin surfaces. The `/arena` page presents a distinct product voice and sample dashboard from the main landing. This should be treated as a product-architecture/design-system issue rather than a small styling mismatch.

The browser inspection showed the live pages at a 1,560 × 900 connected-browser viewport. The green/yellow/red element rectangles and numbered labels visible in the browser screenshots were **inspection-tool overlays, not product UI**, and were excluded from defect severity. The product itself rendered without a visible horizontal page overflow on the inspected public pages. Authenticated/mobile breakpoints remain unverified because the backend was unavailable and the connected-browser inspection was desktop-only.

Security basics review

No committed private key or obvious `sk_live` / `sk_test` secret was found in the inspected source. The deployment spec references secrets through environment variables rather than hardcoding them. Backend startup includes Helmet, CORS, CSRF handling, and a whitelist/transform validation pipe. These are positive controls.

The remaining security concerns are the 31 backend production dependency vulnerabilities, untrusted/raw SVG data, the need to prove the auth token path used by the exam console, and the inability to exercise payment verification and reset-token behavior against a healthy live API. The source contains ordinary backend logging and warning statements; the audit did not find a confirmed production log of a verification/reset token, but this should be checked in deployed notification and exception middleware logs as part of release validation.

Legal and compliance readiness

Privacy Policy, Terms of Service, Help Center, and Contact Us all exist at live routes and contain substantive copy. The privacy notice identifies the Nigeria Data Protection Act 2023 and says the earlier NDPR is referenced where still relevant. It describes account, practice, payment, AI, provider, retention, rights, and under-18 handling. Terms describe monthly plans, pay-per-test access, Paystack checkout, cancellation support, refunds, CBT keys, and FalkeAI limitations.

The principal readiness gap is **implementation-to-policy reconciliation**. The retired Render origin was unreachable, and no PXXL endpoint was available in the repository, so the audit could not verify whether the stated Paystack, cloud, AI-provider, retention, account-deletion, and subscription behavior matches the current PXXL production deployment. Nigerian users are within the scope of the NDPA 2023 framework; NDPR should not be treated as the primary current law. A Nigerian privacy counsel review is appropriate before meaningful paid scale, especially for minors, cross-border processors, AI prompts, payment records, and data-subject requests.

Recommended release order

1. **Restore and monitor the production API.** Confirm `/health`, auth, session creation, autosave, submission, payment verification, and AI requests from the real frontend origin.
2. **Protect exam integrity.** Persist flagged state, make timeout submission recoverable and idempotent, and prove resume behavior across refresh, reconnect, and device change.
3. **Audit the question bank.** Remove hedging/contradictory explanations, reconcile answer keys and options, remove example/dummy assets, and require subject-matter sign-off.
4. **Validate paid access.** Run Paystack test-mode checkout and verification, duplicate/reference replay tests, failure-message tests, and entitlement rollback tests.
5. **Reduce security and maintenance debt.** Triage the 36 production dependency vulnerabilities, pin Node, and clear lint warnings.
6. **Unify product claims and design.** Replace static/demo numbers, reconcile landing/auth/arena copy, standardize brand lockups, and verify PWA names/icons.
7. **Complete authenticated QA.** Test dashboard, mock setup, drills, question bank, exam console, results, FalkeAI, admin, and mobile/light-mode variants with disposable fixtures.

Audit limitations

The audit was intentionally read-only. No account was created, no payment was initiated, no email or reset code was requested, no CBT key was used, and no production data was modified. Authenticated and payment flows could not be responsibly completed

because the repository’s configured Render API was retired/unresponsive and the current PXXL endpoint was not present in the audit inputs. Findings about those flows are therefore classified as unverified or release blockers rather than confirmed user-visible defects unless supported by source evidence.

References

Prepared by: Manus AI
Audit posture: Investigation and reporting only; no fixes, branches, or commits.